

TriVoKo

Phase 2 - Accounts & roles

Time	Start date	Finish date	Status
1 week			Not started

Goal: Safe login for customers, sellers and admins; a customer can apply to become a seller; a seller can only touch their own products.

Real-life example: Every person in the mall gets the right card: shoppers can enter the shop floor, shopkeepers can enter only their own storeroom, and the mall office can open every door.

Step checklist

★ = you type the key logic (Claude explains first, then reviews). "You" = only you can do it.

#	Step	Who	Done
1	Flyway: users, user_roles, addresses; sellers.user_id; seller status PENDING / APPROVED / REJECTED / BLOCKED	Claude	☐
2	Copy EventHub auth: JWT in httpOnly cookie, CSRF double-submit, BCrypt, 5 wrong logins = 15-minute lock; /api/auth/register, /login, /logout, /me	Claude	☐
3	Roles CUSTOMER / SELLER / ADMIN; every new account is a CUSTOMER	Claude	☐
4	Addresses API (max 5, one default)	Claude	☐
5	"Become a seller": POST /api/seller/apply (shop name, city, optional GST) → PENDING; admin approve / reject endpoints (the admin pages come in Phase 6)	Claude	☐
6	Seller products API: create (DRAFT), edit, submit for approval; SellerAccess bean checks ownership on every call	Claude	☐
7	Audit log table + service (who changed what and when)	Claude	☐
8	Dev demo accounts (admin, customers Ravi and Kavya, sellers Chennai Mobiles and Kovai Sports) with the password from .env	Claude	☐
9	Tests: Seller A cannot read or edit Seller B's product (403/404), unapproved seller cannot sell, login lock, CSRF	Claude	☐

Output of this phase

- Working register / login / logout with cookies
- Seller application and approval API
- Ownership checks with tests

Done when (check before moving on)

Check	Passed
A test proves a seller cannot touch another seller's product (403)	☐

Check	Passed
An unapproved seller cannot create products	☐
CI green	☐

Explain it back (in your own words)

Question	Done
Why is the JWT in an httpOnly cookie and not in localStorage?	☐
What does the CSRF token protect against?	☐
How does the server know a product belongs to the logged-in seller?	☐

Finish routine

Check	Done
All tests pass and CI is green	☐
Committed and pushed	☐
Done-when checks shown working in the browser	☐
Session summary + SESSION_LOG written	☐

Skills you practise: Spring Security, JWT, cookies, CSRF, method security, ownership checks

Where your work goes: `backend\...\user`, `...\auth`, `...\seller`, `...\admin`

My notes